

Exploring the Governance Requirements for Enabling MyAccessID

University of Bristol: Christopher Woods, Ashish Tom

University of Cambridge: Deepak Aggarwal, Gwen Dawes

UCL: James Legg, Brian Maher

STFC Hartree: Ayman Izzeldin, Simona Graur, Robin Kennedy-Reid

Published XXXXXXXX 2026. Version 0.1 [DRAFT]

Executive Summary

MyAccessID is an identity federation, run by GÉANT, that lets research infrastructures verify who someone is by trusting the login provided by that person's home institution — drawing on the eduGAIN network of more than 10,000 university identity providers worldwide. It is already used, very successfully, to authenticate researchers logging in to the UK's AI Research Resources (AIRR): Isambard-AI at the University of Bristol and Dawn/Zenith at the University of Cambridge, and to AIRR Portal, the service used to apply for and manage allocations on AIRR. Within AIRR, more than 3000 individuals have had their identities authenticated via MyAccessID across over 300 institutions and at least 20 countries. This project examined how MyAccessID is used across AIRR and whether it could serve as a wider solution for authenticating users of other UK Digital Research Infrastructures (DRIs).

The central finding is positive: MyAccessID authenticates professional (institutional) email addresses reliably, and the resulting ease of login has been repeatedly praised. The value of authentication based on professional email addresses is real and available today, and this report recommends capturing it now rather than waiting for a more ambitious system that is yet to be fully developed and proven at scale.

The project also found, however, that connecting each UK DRI directly to MyAccessID does not scale. Connecting a single new site (UCL) proved very difficult, with no established route, and the MyAccessID operators cannot reasonably onboard hundreds of UK sites one by one. Other challenges included occasional instability in MyAccessID's internal identifiers, surprising behaviour from its optional account-linking features, and the fact that MyAccessID is a single point of failure — one outage blocked an entire training workshop. Many people entitled to use UK DRIs (for example in government, industry and SMEs) are also not part of eduGAIN at all, and need alternative ways to authenticate.

The report's main recommendation is therefore that the UK should not connect every DRI directly to MyAccessID, but should instead establish one or more “[Identity Connectors](#)” that sit between UK DRIs and MyAccessID. Each DRI connects once to a Connector, and the Connector handles the MyAccessID connection on its behalf. The login experience for

researchers is unchanged, but the approach is scalable and creates a single place to authenticate the professional email address as the identity, to connect non-eduGAIN organisations (via standard protocols or an email-based login), to add resilience against outages, and to sustain a community of practice. Supporting recommendations cover the governance and support arrangements such a service would need, and the policy checks — including subsidy and export control — that follow when a person’s professional identity changes.

The detailed, categorised recommendations are set out in [Section 1](#), with the supporting evidence in [Section 2](#).

1. Recommendations

Each recommendation is categorised (Must / Should / Could Have), given an indicative timescale within the 5-year Roadmap and an estimate of resources, and states the basis on which it is made with links to the supporting evidence in [Section 2](#). The focus is on what can be achieved quickly with what exists now, so we target work that can be completed within the first year. Resources are estimates that can be refined based on what else needs to be completed as part of the overall Network+ Roadmap.

The evidence assessed for these recommendations comes from the project documented in [Section 2](#), and the input behind them was provided by the authors of this report — who include the AIRR Operators, represented by the authors from the University of Bristol and the University of Cambridge, who operate the Isambard-AI and Dawn/Zenith services respectively — and from discussions and questions asked and answered during the project workshops, and discussions with representatives from MyAccessID and Jisc. This applies equally to the governance and policy recommendations below ([MYAID-2](#) and [MYAID-5](#)) and to the technical ones.

MYAID-1 — Establish one or more UK Identity Connectors as intermediaries to MyAccessID · Must Have · Timescale: Year 1, ~6 months to a first production service (short term). Foundational — [MYAID-2](#), [MYAID-3](#), [MYAID-4](#) and [MYAID-8](#) depend on it.

The UK should fund the design, build and operation of one or more “Identity Connectors”: shared services that sit between UK Digital Research Infrastructures (DRIs) and MyAccessID. Ideally one should be funded, but multiple could be created depending on community, resilience or national need. Rather than every DRI negotiating its own direct connection to MyAccessID, each DRI connects once to a Connector, and the Connector handles the MyAccessID connection on its behalf. To a researcher logging in, the experience is identical; the difference is entirely in the plumbing beneath. Each Connector should be built on a standard identity proxy (e.g. Keycloak) using standard protocols (OpenID Connect – OIDC – or SAML), so a new DRI can be connected quickly and consistently. The Connector should also be the single place where resilience is added — for example by caching recent authentications or offering a backup login route, e.g. temporarily enabling Email Authentication — so that a MyAccessID outage does not immediately block all new logins to UK services.

Basis: connecting a single new site directly proved disproportionately hard. Connecting UCL, our planned exemplar, was time consuming and challenging, with no established route via Jisc, and the MyAccessID operators understandably cannot onboard hundreds of UK DRIs individually (2.3.7). By contrast, our trial Connector routed UCL and Hartree authentication through a Keycloak realm to MyAccessID and a demo email authenticator, demonstrating that a Connector is technically straightforward to build (2.4). Centralising the connection also gives a single place to enforce a minimal, professional-email-only connection (MYAID-2) and to add resilience against the outages observed (2.3.5).

Resources: build ~1.5–2.0 FTE for ~3–6 months. Aligns with: existing AIRR (Isambard-AI, Dawn/Zenith) IAM work and the UCL + Hartree trial Connector. Collaboration: GÉANT/MyAccessID, Jisc, the IAM4DRI community. Operational resources to be negotiated depending on required SLAs / KPIs.

MYAID-2 — Authenticate the professional email address, use it as the identity, and connect to MyAccessID in a minimal mode · Must Have · Timescale: Year 1, configured as part of the Connector build (first ~3 months). Depends on MYAID-1.

The Connector(s) should authenticate the user's **professional or institutional email address** — the address issued by their university or employer — exactly as supplied by their home institution via eduGAIN, and should use that email address as the person's identity. The Connector should connect to MyAccessID in a restricted, "professional-email-only" mode that does not draw on MyAccessID's optional account-linking and profile layer. The UK should also engage MyAccessID's governance to explore whether this restricted mode could be offered as a formally supported "MyAccessID-lite" service. We specifically recommend against relying on any other identifier — particularly a machine-readable identifier such as a UUID — as the primary identity.

Because compliance is based on an individual's **professional identity**, a change of employer or institution changes that identity and potentially invalidates any compliance checks that previously took place. **Changes in professional identity must trigger the appropriate checks before access continues.** Basing authentication on an individual's professional email address thereby triggers this re-evaluation automatically. Since the process can be onerous, we therefore also recommend developing streamlined — and where possible partly automated — processes for these changes. These processes are where the relevant policy obligations are discharged: subsidy-control and export-control checks, the Access Terms agreed between each DRI and the person's institution or employer, and the liability cover for the individual's actions, alongside project-membership re-approval and the corresponding account updates. Data-protection and cybersecurity questions arising at connection time should be handled through the Community of Practice (MYAID-6).

Basis: MyAccessID issues a UUID intended to be permanent, but the AIRR operators saw these change for individuals, and on rare occasions for an entire institution overnight, which broke logins and required manual account deletion to repair (2.3.1). MyAccessID's higher account-linking layer also let users present a different (sometimes personal) email

than expected, causing failed access and profiles that were hard to repair (2.3.2). Authenticating the professional email as supplied by the home institution, in a minimal connection mode, avoids both classes of problem (see also the canonical-address friction in 2.3.3 and 2.3.4). **Tying identity to the professional email also forces the compliance, subsidy-control and export-control checks that must accompany a change of employer; the AIRR Operators and Allocators (e.g. DSIT, UKRI) treat this as a requirement**, but the update process is currently largely manual (2.3.6).

Resources: negligible incremental build — configuration within the proposed [MYAID-1](#) effort. The main additional cost is governance-engagement time with MyAccessID for the “MyAccessID-lite” conversation. Aligns with: AIRR’s existing connection configuration. Collaboration: GÉANT/MyAccessID governance.

MYAID-3 — Add authentication routes for users not covered by eduGAIN: third-party OIDC/SAML IdPs and an email-a-code authenticator · Must Have · Timescale: Year 1, ~3–6 months after the Connector is live. Depends on [MYAID-1](#).

Many people entitled to use UK DRIs are not in eduGAIN — for example staff at government bodies, research institutes, industry and SMEs. The Connector(s) should therefore offer two further routes, both still restricted to professional/institutional email addresses (never personal addresses): (a) connect third-party organisational IdPs on request, using standard protocols (OIDC or SAML), where a named, responsible person at the organisation requests a connection via a simple form, and the time taken to connect a new organisation is tracked as a service KPI; and (b) an “email-a-code” authenticator, which emails a short single-use code to the professional address and authenticates the person if they enter it correctly. The email-a-code route needs no password and confirms the person currently controls that mailbox. Where stronger assurance is needed it can optionally be paired with multi-factor authentication — though, because password/MFA resets typically go via email, the added assurance of MFA should be assessed case by case.

Basis: Isambard-AI already connects business IdPs (e.g. Okta, Azure AD) for stakeholders such as AISI and the NCC via OIDC (2.4.1); Dawn/Zenith and the AIRR Portal already run email authenticators in production (2.4.2). Both mechanisms are proven and were recommended for the Connector (2.4.4, 2.4.5).

Resources: build ~0.5–1.0 FTE for ~3–6 months. For operations, there would be a small ongoing effort per new organisation connected, resourced as part of the connector operational funding. Aligns with: existing Bristol OIDC connections and Cambridge email-authenticator deployments.

MYAID-4 — Provide an “Identity Provider of Last Resort” for users with no viable IdP · Should Have · Timescale: Year 1, ~3-6 months (after [MYAID-1](#) in parallel with [MYAID-3](#));

For the minority of users who cannot use any of the routes above, the Connector(s) should offer an Identity Provider of Last Resort: a managed login (professional email + password +

MFA) operated by the service. It should still use the person's professional email as their identity, and should cover cases such as users whose organisation's IdP is not yet connected, or users on personal addresses who hold paperwork from a trusted organisation providing liability cover. This route should be explicitly transitional: there should be an active effort to connect the relevant organisational IdPs and migrate these users onto a proper OIDC/SAML route over the course of the Roadmap.

Basis: all AIRR sites already run such a last-resort IdP (e.g. AWS Identity Centre at Bristol, Keycloak at Cambridge), and report that it works but is costly to run and to keep clean — accounts must be actively reviewed and revoked, and users struggle with passwords and MFA resets, eroding the savings of federated authentication (2.4.3). It is therefore valuable but should be minimised, hence *Should Have* rather than *Must Have* (2.4.6).

Resources: build - ~0.5-1.0 FTE for ~3-6 months, developed using the same team as MYAID-3, plus ongoing operational account-administration effort that grows with the number of last-resort accounts — a cost that should fall over time as users migrate to proper IdPs. Aligns with: the existing AIRR last-resort IdPs.

MYAID-5 — Put in place a governance regime and a paid support contract, with SLAs, resilience and clear operational targets · Must Have · Timescale: Year 1, ~6–9 months to agree (start early to allow contracting lead time); operates for the full 5-year Roadmap.

The UK should establish formal governance and a paid support relationship covering the Identity Connector operator(s) and, where relevant, MyAccessID. The contract should set out service level agreements for operational uptime, for onboarding new DRIs, and for connecting new IdPs; a ticketing system with documented issue resolution; and a public status page with historical uptime. It should also state the operational expectation explicitly (e.g. 24/7 or 9/5) and resource operations accordingly, because an outage of the Connector or of MyAccessID blocks all new logins to UK services. A backup authentication mechanism (see MYAID-1) should form part of the resilience plan.

Basis: MyAccessID has had very high uptime, but it is a single point of failure: one outage at the start of a training workshop blocked all attendees from logging in (2.3.5). The current direct relationships are informal and depend on goodwill, with no clarity on who funds support (2.3.7). The UK needs a defined, funded operational footing rather than reliance on best-effort.

Framework over 5 years: Year 1 — stand up the governance regime and support contract alongside the Connector(s) (MYAID-1); agree initial SLAs (uptime, DRI onboarding, IdP connection); put ticketing and a status page in place; and open the governance conversation with GÉANT/MyAccessID (including the “MyAccessID-lite” arrangement MYAID-2), stand up organisational structures to enable Identity Connector operator(s) to enter into similar support contract relationships,. **Annually thereafter** — review the SLAs against real operational data and adjust; expand the connected DRIs and IdPs; and revisit the uptime target (24/7 vs business hours) against demonstrated demand. Continue to extend governance to all UK DRIs, establish a sustainable funding / cost-recovery model,

and review the framework — and the deferred richer-federation question ([MYAID-7](#)) — periodically.

Resources: support-contract cost with MyAccessID/GÉANT [cost to confirmed]; ~0.2–0.5 FTE service-management/governance effort ongoing; operational FTE captured under [MYAID-1](#). The chosen uptime target (24/7 vs business hours) is the main cost driver and a decision for the UK. Aligns with: DSIT/UKRI allocation governance. Collaboration: GÉANT/MyAccessID, Jisc.

MYAID-6 — Establish a Community of Practice, run by the Connector operator(s), to help UK sites adopt federated identity · Should Have · Timescale: Year 1 to establish (~3 months), sustained across the Roadmap.

The Connector operator(s) should be responsible for engaging and sustaining a Community of Practice around federated identity for UK DRIs, and for developing, sharing and co-delivering practical materials. This should cover at least: deploying a suitable identity proxy (e.g. Keycloak); completing the paperwork for a new connection and answering the data-protection and cybersecurity questions that arise (both locally and from the MyAccessID operators); and connecting to the Connector robustly.

Basis: during the project we seeded this community — a project website with worked examples, two recorded workshops, and the “IAM4DRI” mailing list ([2.5](#)). This was valuable, but the difficulty of connecting UCL showed that a peer community alone is not enough: it needs an operator that is itself embedded in the community and has a direct stake in its success — actively running, sustaining and contributing to it, rather than publishing materials at arm’s length ([2.3.7](#)).

Resources: ~0.2–0.5 FTE ongoing, plus minor hosting and event costs [cost to be determined]. Aligns with: the existing project website, workshops and IAM4DRI mailing list. Collaboration: the UK DRI community, Jisc and GÉANT.

MYAID-7 — Realise the value of professional-email authentication now; defer richer attribute or authorisation federation to later Roadmap phases · Must Have · Timescale: Year 1 (a strategic decision to take at the outset); revisit richer federation as a later phase (Year 3+).

The UK should commit now to deploying robust authentication of professional email addresses across UK DRIs, using the existing, proven building blocks above, rather than waiting for a more ambitious system. It should explicitly scope out — for the short and medium term — federating richer attributes, team membership or access-control/authorisation, and instead revisit these as a distinct, later phase of the Roadmap once the authentication layer is established.

Basis: authentication of the professional email is already delivering value at scale at the AIRR sites and is widely praised for ease of use ([2.2](#)). By contrast, even seemingly simple

richer attributes are hard to agree and deliver consistently across a distributed federation — the project found genuine difficulty even in agreeing what a person’s “canonical” email address is (2.3.3), and saw how brittle additional machinery (UUIDs, account-linking, address changes) can be (2.3.1, 2.3.4). Systems that do more do not currently exist in deployable form, so the pragmatic course is to capture the value of authentication, based on professional email addresses, now.

Resources: primarily a strategic/governance decision — negligible direct cost; delivery effort is captured under [MYAID-1](#)–[MYAID-6](#). Aligns with: UK DRI Roadmap planning.

MYAID-8 — Support OIDC-backed SSH access by signing SSH certificates (e.g. via clifton and conch) · Could Have · Timescale: Year 1, ~2–3 months; optional enhancement — no other recommendation depends on it.

Where DRIs offer command-line (SSH) access, the Connector(s) should optionally support signing SSH certificates from the same OIDC login, and provide guidance for sites wishing to deploy this. This lets researchers use their federated login to obtain SSH access rather than managing separate SSH keys.

Basis: Bristol already solves this for Isambard-AI using the clifton and conch tools, which sign SSH keys via an OIDC workflow (2.5). The approach is proven in production but applies only to the subset of services and users that use SSH, so its impact is real but narrower — hence Could Have.

Resources: ~0.25 FTE for ~2–3 months to package guidance and offer a shared certificate-signing service; minimal ongoing operational cost. Aligns with: the existing Bristol clifton/conch deployment. Collaboration: the clifton/conch maintainers.

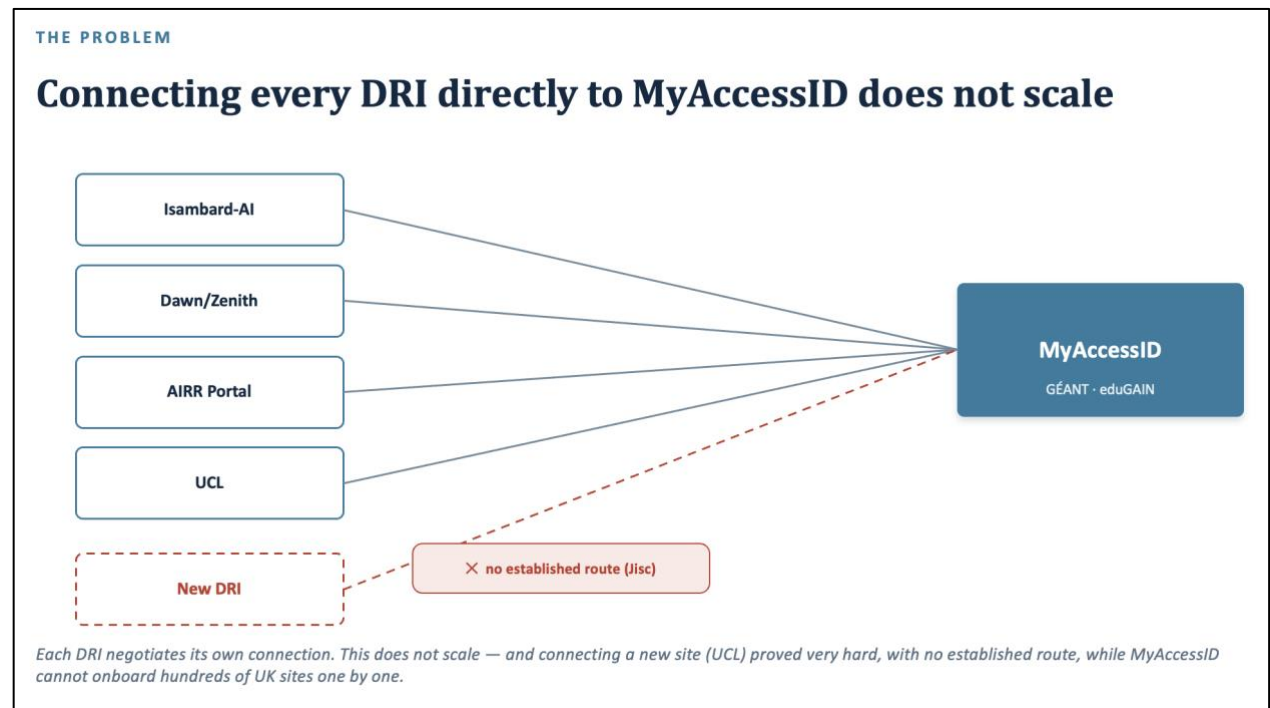
Key risks and assumptions

- **Dependence on MyAccessID / GÉANT.** The approach assumes the continued availability of MyAccessID and a workable, funded support relationship; a change in its service model, terms or funding expectations would affect the UK approach. Mitigated by the support contract and governance engagement ([MYAID-5](#)) and Connector-level resilience ([MYAID-1](#)).
- **A shared single point of failure.** Even behind Connectors, MyAccessID remains a common dependency whose outage blocks new logins. Mitigated by caching / backup authentication ([MYAID-1](#)) and uptime SLAs ([MYAID-5](#)).
- **Reliance on stable professional email addresses.** Using the professional email as the identity assumes home institutions present consistent, canonical addresses; the project observed inconsistency between and within institutions. Mitigated by the minimal-mode connection and supporting tooling ([MYAID-2](#)).

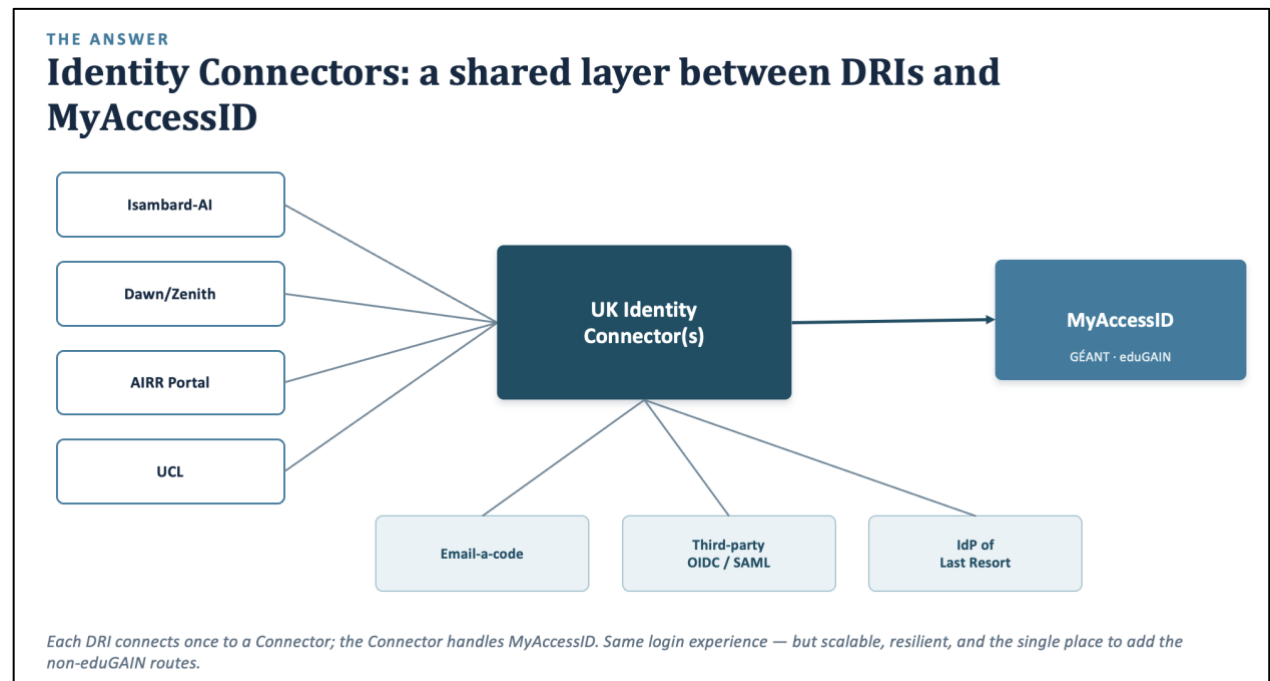
- **Growth and cost of the last-resort route.** The Identity Provider of Last Resort is costly to run and could expand if migration to proper IdPs stalls. Mitigated by treating it as explicitly transitional ([MYAID-4](#)).
- **Adoption depends on the community.** The benefits accrue only if UK DRIs adopt; uptake may stall without an operator that has a direct stake in the community ([MYAID-6](#)).

Proposed Identity Connector Architecture

The current architecture is that each DRI connects to MyAccessID directly. Each site is responsible for requesting a connection, managing authentication from IdPs not supported by MyAccessID, and managing outages / support individually.



The proposed architecture is that each DRI would connect through an authentication proxy – the Identity Connector. This is based on, e.g. Keycloak, and routes authentication requests to MyAccessID for supported IdPs, and other routes for those that aren't, e.g. company IdPs, Email authenticators and – in exceptional cases – the Identity Provider of Last Resort. The Identity Connector operators maintain a funded support relationship with MyAccessID, and handle the scaling of support across the UK DRIs.



2. Report

2.1 Background

MyAccessID is an identity federation provided by GÉANT[\[a\]](#). It is provided to give the European research community a single, trusted way to authenticate people who are trying to access research infrastructures. MyAccessID lets researchers authenticate and identify themselves primarily via eduGAIN[\[b\]](#). It does support authentication via other trusted Identity Providers (IdPs), although these were not the focus of study for this report. For this report, it is the capability of MyAccessID to authenticate researchers from across the eduGAIN-connected federations, internationally authenticating against more than 10,000 IdPs, that is being assessed as its primary benefit.

MyAccessID was chosen as one of the identity authentication mechanisms used by the UK's AI Research Resources (AIRR), namely Isambard-AI at the University of Bristol, and Dawn/Zenith at the University of Cambridge. In the project underpinning this report, we explored how MyAccessID was being used by the AIRR sites, and explored whether MyAccessID could be a viable solution for identity authentication for other Digital Research Infrastructures (DRIs) in the UK. Specifically:

- We identified the challenges that block or slow down adoption of MyAccessID by UK DRI providers, and possible solutions. This included surfacing how MyAccessID is used by AIRR and what issues exist (Sections [2.2](#) and [2.3](#)), and documenting case studies in which sites that have adopted MyAccessID help new sites gain their connections.
- While MyAccessID solves the challenge of authenticating institutional (academic) email addresses, it does not provide many options for authenticating other professional email addresses, e.g. those from Research Institutes, Government or Business. We explored other potential solutions, and how these could be deployed via “Identity Connectors” (Section [2.4](#)).
- Finally, we documented routes by which a UK-wide rollout of MyAccessID could be achieved in a sustainable and well-governed way, including bringing together a community of practice around federated identity and access management to share expertise and build partnerships that overcome barriers to adoption (Section [2.5](#)).

2.2 How AIRR uses MyAccessID

MyAccessID is used very successfully at the AIRR Sites for authenticating researchers accessing the Isambard-AI and Dawn/Zenith AI supercomputers. To understand how, it is worth clarifying the difference between authentication and access control.

Authentication is the process by which an IdP (e.g. a university) asserts that the person who is trying to connect is who they say they are. Practically, and oversimplified, this means that the DRI would trust the researcher's home IdP to perform a login check, and then send a trusted token to the DRI to confirm that the researcher logged in successfully.

The contract or assertion provided by the home IdP to the DRI is that “the person who contacted you has control over the proffered identity in the home IdP”.

Access control is the process by which a DRI decides whether or not someone is allowed to access a service or resource. While authentication is asserting “they are who they say they are”, access control is asserting “they can access what they have requested to access”.

In AIRR, MyAccessID is used **only** for authentication. Each AIRR site manages access control separately. Access control for both sites is managed using the Waldur software, which locally provides project team membership controls, and gates access to resources based on whether those resources are attached to the project, and that the person connecting has an appropriate role within that project.

Note that Access Control was outside the scope of the project. The scope was looking only at how MyAccessID could be used for authentication.

Another key decision taken by the AIRR operators was that authentication was only for the following attributes of the person trying to connect:

- Their professional email address (i.e. the email address provided by their university or employer. This is distinct from a personal email address, e.g. from gmail etc).
- Their first name
- Their last name

The AIRR Operators then chose to set the “subject” (i.e. the unique identifier for the person connecting) to the professional email address. A consequence of this is that if someone changed employer or institution, then their professional email address would change, and thus their identity in AIRR would change. We will discuss later the pros and cons of this decision.

With these choices, deployment and use of MyAccessID has been highly successful, and the ease of login has been repeatedly praised by researchers. Currently, over 3000 people have connected to AIRR using MyAccessID for authentication, across more than 300 different institutions and at least 20 different countries. Aside from a few challenges detailed below, the AIRR operators’ experience of MyAccessID has been highly positive.

This success is the basis for adopting an existing, eduGAIN-backed service that authenticates professional email addresses, in preference to building a home-grown solution (see [MYAID-1](#) and [MYAID-7](#)).

2.3 Challenges and issues

MyAccessID has proven to be an excellent solution for authenticating eduGAIN-backed identities. However, there have been a small number of challenges.

- **2.3.1** MyAccessID itself generates and uses a unique UUID-based identifier to identify each MyAccessID user. This is because MyAccessID does not tie identity to a single email address, but instead allows individuals to link multiple email addresses

to their MyAccessID account. The MyAccessID UUID is sent as the subject in an authentication response. While this UUID is meant to be permanent, the AIRR site operators report having seen it change for individual researchers. In rare occasions, the UUIDs for ALL people connecting from an individual university changed overnight. The AIRR site operators were unsure of the causes of these changes. The impact when this happened was that the email address of the researcher then presents as a different subject. This confuses the identity proxy used by AIRR (Keycloak[\[c\]](#)), causing the authentication request to fail with an obscure error. The fix is to delete the Keycloak accounts for affected users, so that they are remade using the new MyAccessID identifier on the next login. These experiences point to using the professional email address being authenticated as the subject, with DRIs mapping the email address to the subject, and to avoiding any other identifier — especially a machine-readable one such as a UUID, which is hard for a human to understand (the basis for [MYAID-2](#)). While such UUIDs are meant to be “permanent”, the evidence suggests that identity federations are distributed and brittle, and assuring that something other than the email address is “permanent” is a significant implementation challenge. As noted below, email addresses are also not “permanent”.

- **2.3.2 MyAccessID works best for AIRR when it was used only for authenticating the professional email address of the person connecting.** However, MyAccessID provides a higher layer, which uses the UUID-based identifier to enable a user to connect multiple email addresses to the same MyAccessID account. This means that a researcher can present with one email address, but then authenticate with another. This can be a security concern. More annoyingly, a researcher logging in via their home IdP, and thus expecting to present their professional email address, may find that instead one of their personal email addresses is signed and sent to the AIRR site instead. This leads to downstream access challenges, as the AIRR access controls are gated on authenticated professional email addresses. In these cases, the researcher logs in with their professional address, but their personal address is presented, and they are denied access with an error explaining they used the wrong email. Fixing this is challenging, as it requires a difficult profile update via the MyAccessID profile page[\[d\]](#). Explaining this process to the affected researcher is complex, especially if they have managed to get their profile into a broken state (e.g. the AIRR Operators report seeing MyAccessID profiles that are completely broken, and which appear to be in a “deleted” state, despite authenticating fully). This can be fixed by contacting the MyAccessID technical team. However, it is a layer of complexity that is unnecessary given how the AIRR Sites use MyAccessID. MyAccessID has communicated fixes to the AIRR Sites to close the security issue, and shown how to use MyAccessID attributes to ensure that the professional email address is the one that is authenticated, but it makes the process of setting up a connection more complex. Plus, since this is not the default, it can lead to surprising behaviour for DRI sites when they first try to use MyAccessID. These reported experiences point to connecting to MyAccessID so that only the professional email address is authenticated, and to engaging MyAccessID’s governance about a “MyAccessID-lite” service that acts purely as a professional, eduGAIN-backed email-

authentication layer without the profile or connected-accounts layer on top (the basis for [MYAID-2](#)).

- **2.3.3** MyAccessID authenticates the professional email address, but this may not necessarily be an email address known about or expected by the person connecting. For example, the AIRR Operators report that there are many universities which give their staff and students multiple variations of their email address. For example, there could be a “short” address, based on the person’s username, and a “long” address, based on a combination of their first and last names. Or there could be a department address, where the department or group is a subdomain in the address, versus a university address, where only the university domain is present. While the person logging in may prefer and use one of these variants, it is only the variant that is presented canonically to MyAccessID via eduGAIN that is signed and authenticated. This can lead to people being confused as to why their email is “wrong”, or raising tickets to request that the AIRR Operators change the email address on the AIRR Portals. More annoyingly, it leads to a common service issue where a Project Lead invites a Project Member onto a project using the “wrong” email address (the one they know their project member by, rather than the “canonical” email address sent to MyAccessID). Even more annoyingly, there is little to no consistency, e.g. even within the same university the AIRR Operators report seeing cases where a university IdP presents different variants for different people, often with no logic or reason. Fortunately, the AIRR Operators don’t report seeing any cases where the variant used as the individual’s “canonical” address changed, but this is still a point of friction for initial onboarding and invitation onto projects. It will also cause clashes if email-based authenticators (mentioned later in this report) are more widely rolled out. Currently, the AIRR Operators solve this problem by making sure that the “canonical” email address is made visible on error messages, and asking that affected people contact their project lead to let them know to use the “right” address. There are also tools in MyAccessID to let someone see their “canonical” email address when they connect – and to then change this if they want (see [2.3.4](#)). Based on this, we noted the challenge, in a distributed identity federation, of even agreeing something as seemingly simple as the definition of the “canonical” email address, and it raises the question of how ambitious it would be to rely on IdPs to consistently implement more complex attributes. This points to providing tools that let people see, and share, their “canonical” email address (so that email-based invitations work), and to engaging UK eduGAIN-backed IdPs towards a consensus that the “canonical” address is the one the person most identifies with — for example their “send from” address (the basis for [MYAID-2](#)).
- **2.3.4** The AIRR Operators report seeing that people can change their canonical email address presented by MyAccessID. The AIRR access model is based on two requirements: 1. that the professional email address is unchanging, and 2. that the professional email address authenticated exactly matches that supplied by the eduGAIN-backed IdP. This capability of MyAccessID breaks both requirements. MyAccessID have communicated ways to use attributes to ensure that only the professional email address as supplied by the home IdP is used. But, by default, a

naïve connection would not use this, and so there is the potential for surprising results. This reinforces the finding in 2.3.2: any UK DRI should connect to MyAccessID so as to authenticate only the professional email address as supplied by the person's home IdP, and the UK should work with the MyAccessID team towards a MyAccessID-lite service that authenticates only eduGAIN-backed professional email addresses (the basis for MYAID-2).

- **2.3.5** MyAccessID has had remarkably high uptime during the 2+ years it has been relied on by the AIRR Sites. However, it is a single point of failure, and outages of MyAccessID prevent people from authenticating, and thus initiating new logins to the services. While outages are extremely rare, and often very rapidly resolved, the AIRR Operators report one outage that happened at the start of a training workshop. This completely blocked the running of the workshop, as the attendees could not authenticate and log in. This is the basis for a funded support relationship with MyAccessID, with clear service level agreements (SLAs) and uptime targets (MYAID-5), and for a backup authentication mechanism that can be deployed when MyAccessID is unavailable (MYAID-1); possible backup mechanisms are discussed in Section 2.4.
- **2.3.6** A deliberate choice by the AIRR Operators was to tie identity to the professional email address. There are several benefits to this, but a few problems. The benefits relate to compliance, and to forcing the necessary compliance and due diligence checks that are required when an individual changes institution or employer. In such a case, the person cannot be assumed to still retain their project membership and levels of access, as these are tied to their institution or employer, with Access Terms being agreements between DRI sites and those institutions / employers. In addition, some changes in professional identity would bar people from continued access, e.g. moving into industry, thereby triggering subsidy control legislation, or moving to a company or institution whose links would trigger export control violations. Or, if an individual loses professional identity, then a third party needs to be identified who can supply the paperwork necessary to act as an employer, and provide liability cover for the individual's actions on the DRI. As such, the AIRR Operators and the AIRR Allocators (e.g. DSIT and UKRI) treat it as a requirement that there is a process attached to changes in professional identity, and using the professional email address as the primary identity automatically fulfils this requirement. However, the disadvantage is that – if a change in professional identity is requested – then the process of updating an individual's access account to use the new professional email address is quite manual. The lead of every project in which they are a member needs to be contacted, and both they, and the allocator of each of those projects needs to approve the change in professional identity. Once agreed, the individual's access account (e.g. in Keycloak) needs to be updated so that the subject and email are set to the new professional email address. This is all doable, but a little painful. Fortunately, changes in professional identity are less frequent than, for example, login requests or begin or end project requests. The AIRR Operators report only a few dozen changes in professional identity requested, compared to thousands of researchers and nearly a thousand projects using AIRR

services. However, this points to developing processes that streamline or automate the necessary compliance checks, project-membership checks, and the resulting account updates (e.g. in Keycloak), so that changes in professional identity can be processed more easily (the basis for [MYAID-2](#)).

- **2.3.7** Connecting to MyAccessID is very simple. Assuming the DRI site is using a good OpenID Connect (OIDC) proxy, e.g. Keycloak, then creating a connection requires setting only a small number of parameters and then exposing the resulting login button. The process takes less than an hour. The MyAccessID team are fantastic, and provide lots of help and support, and even provide a “sandpit” in which new connections can be tested before production deployment. The challenge though is finding a route by which the MyAccessID team will allow a new DRI to use MyAccessID. The AIRR site operators had pre-existing professional connections to the MyAccessID operators, and the AIRR programme was of sufficiently high profile that it was possible to request a connection directly. However, this “hands-on” route would not scale to the potentially hundreds or thousands of UK DRI sites trying to get a new connection. The MyAccessID operators – rightly – do not want to be put in a position of having to respond to and support every UK DRI site that wants a connection. Especially so as it is unclear whether or how the UK is funding support to MyAccessID for this work. In this project, we attempted to find a solution to this by creating case studies of how UK DRIs could successfully gain a new connection. The plan was to start with UCL, and then use the path forged by UCL to help other UK DRIs connect. However, connecting UCL was extremely challenging. The preferred route – going via Jisc (the UK’s National Research and Education Network (NREN) that connects to GÉANT) – proved to be very complex. There was no established process, and it was unclear whether or how Jisc would support UK DRIs in trying to make a MyAccessID connection. While UCL did manage to get a MyAccessID connection by the end of this project, the experience demonstrated that scaling up this kind of approach to potentially all UK DRIs would be extremely challenging. This is the basis for the central finding of this report: rather than connecting every UK DRI directly to MyAccessID, the UK should develop one or more “Identity Connectors” that act as intermediaries ([MYAID-1](#)). The Identity Connectors would connect to MyAccessID, while UK DRIs would connect to the Identity Connectors. Requests for eduGAIN-connected identities would flow from the UK DRI to MyAccessID via those Connectors. The user experience would be the same, but the plumbing underneath would provide a scalable solution, while also managing the technical requirements from the recommendations above. For example, the Identity Connector(s) could ensure that they only authenticate the professional email address, and that they connect to (or scope a connection down to) a “MyAccessID-lite” type service. They could also provide backups to MyAccessID, e.g. by caching authentications (to cover outage blips) or by providing alternative authentication routes that could be used in case of MyAccessID outage. These possibilities are discussed in [Section 2.4](#).

2.4 Authenticating identities that are not backed by eduGAIN

MyAccessID has proven to be excellent at authenticating identities that are backed by eduGAIN, i.e. those of (mostly) academic researchers at universities and some research institutions. However, there are a large number of people who have permission to use UK DRIs whose Identity Providers (IdPs) are not connected to eduGAIN. Different authentication routes are needed for these individuals.

The AIRR site operators used a number of mechanisms for authenticating such individuals:

- **2.4.1** The Isambard-AI operators allow connections from the Bristol Keycloak to other OIDC-compatible IdPs. This is used to authenticate identities for key stakeholder organisations, e.g. the AI Security Institute (AISi) and the NCC (site at which Isambard-AI is based). Other organisational OIDC IdPs can be connected if the request is approved. Using this route, identities that are backed by business IdPs (e.g. Okta and Azure AD) are supported, with the professional email address of people connecting authenticated using a similar workflow to that used by people authenticating via MyAccessID.
- **2.4.2** The Dawn/Zenith operators and the AIRR Portal operators additionally allow connections to their Keycloak from “Email authenticators”. An Email Authenticator is one that emails a short code (typically a random 6-digit number) to the email address of the person connecting. The person connecting is asked to enter this code into the login box, with the email address authenticated if they are able to enter the correct number. Email authenticators are now widely used, as they don’t require the individual to set up and remember a password, and they provide a good level of assurance that the individual has current access to read the emails sent to the presented email address. This test assures that the individual authenticating has current read-level access to the emails in the account, and gives confidence that they have write-level access too (as they would likely delete the login-attempt emails, or else the “real” owner of the account would notice them piling up and would raise a support request). A challenge of Email authenticators is that some people delegate access to their email accounts, meaning that the level of assurance that it is truly the individual, rather than a delegate authenticating is lower. As such, for more secure access, Email authenticators may be worth pairing with multi-factor authentication (MFA), e.g. additional one-time password codes or passkeys via authenticator apps. However, since most “I forgot my password” or “I lost my authenticator app” requests would send reset information via email, they would allow the delegate to perform the reset as well. So, any combination of an Email authenticator with MFA should evaluate whether the MFA truly adds an extra layer of security or assurance.
- **2.4.3** The AIRR operators at all sites additionally provide and manage their own IdP, often called the “Identity Provider of Last Resort”. This provide identities for individuals who can’t use the above routes, or for access to services that cannot use the Email authenticator. These identities still use the professional email address of the individual, but authenticated now by entering a password and MFA challenge response to a site-managed IdP (e.g. AWS Identity Centre for Bristol or Keycloak for

Cambridge). The benefit is that this works, and is easily replaced by a “proper” authentication route for that professional email address once such a route becomes available. However, a major disadvantage is that these identities have to be managed, and checking if they should be revoked, e.g. because the individual has changed their professional identity, is a major piece of manual work and is quite a challenge. In addition, running an IdP is a lot of work – people struggle creating the accounts and setting passwords when they first connect, individuals lose or need to reset passwords or MFA devices etc. This work detracts from the savings that are made by outsourcing authentication to a federation.

In addition, during the project we developed a trial “Identity Connector” that enabled UCL and Hartree to route authentication requests via a development “connector” Keycloak realm to MyAccessID and a demo email authenticator. This showed that, technically, developing and deploying an Identity Connector is straightforward.

This experience reinforces the case for one or more Identity Connectors acting as identity proxies, routing authentication requests from UK DRIs to the appropriate identity federation or IdP ([MYAID-1](#)). Beyond connecting to a “MyAccessID-lite” service, the evidence points to the Connector(s) providing the following further routes:

- **2.4.4** An “Email authenticator” that optionally provides MFA or higher-level assurance around the authenticated professional email address, gated to professional email addresses only and never allowing authentication of personal email addresses (the basis for [MYAID-3](#)).
- **2.4.5** Routes by which third-party organisations (e.g. SMEs, Government, Research Institutes, Industry) can request that their IdP is connected, e.g. via OIDC — ideally via a form, with the time to connect a new organisation tracked as one of the KPIs used to evaluate the operators of the Identity Connector(s) (the basis for [MYAID-3](#)).
- **2.4.6** An “Identity Provider of Last Resort”, only for cases where no viable IdP is available from the routes above (the basis for [MYAID-4](#)). This would cover people with personal email addresses but who have paperwork from trusted organisations who can provide liability cover for the individual’s actions. It would also cover individuals from organisations who do not yet have their organisational IdP connected. Note that the professional email address of these people should be used, and efforts should be taken to try to connect these IdPs, so that these individuals can be migrated to an OIDC-backed authentication workflow.

2.5 Community of Practice

We identified during the project that deployment of MyAccessID would require providing upskilling and community / peer support to sites who were curious or on the path to adoption. We identified that there are three main areas where support was needed:

- Adoption of suitable identity proxying software, e.g. Keycloak. This is used to relay requests for authentication to the appropriate IdP or identity federation.

- Advice and support on how to fill in the paperwork to get a new MyAccessID connection, and how to address any data privacy or cybersecurity questions raised through the process (both locally and by the MyAccessID operators).
- How to support login and authentication methods that are more challenging to route through identity proxies, e.g. SSH.

To this end, we created a website[e] where we shared information on how the AIRR sites solved these problems, and ran two workshops (talks recorded and placed online). We also created the “IAM4DRI” mailing list, which currently has XXX subscribers. The aim was to seed the start of a MyAccessID Community of Practice. This community would provide peer support, share best practice, and help each other and new sites in their path to adopting MyAccessID. This has been successful, however the difficulties outlined in 2.3.7 in getting a connection for UCL showed that this community alone would be insufficient. This points to the Connector operator(s) being responsible for engaging and sustaining the Community of Practice, and for developing, sharing and co-delivering materials that help UK IdPs deploy identity proxies (e.g. Keycloak) and build robust connections to the Identity Connector(s) (the basis for MYAID-1 and MYAID-6).

In addition, at Bristol the problem of supporting SSH connections via Keycloak is solved via the clifton[f] and conch[g] software. These sign SSH keys via an OIDC workflow, thereby allowing people to use an OIDC login to SSH into Isambard-AI. This points to providing guidance on deploying clifton and conch, and to the Identity Connector(s) offering a similar SSH certificate-signing service (the basis for MYAID-8).

Acknowledgments

We acknowledge the support of the National Federated Compute Services who have funded this work through the Engineering and Physical Sciences Research Council (EPSRC) under Grant No. EP/Z534493/1

References

- [a] - <https://trustidentity.geant.org/myaccessid/>
- [b] - <https://edugain.org>
- [c] - <https://www.keycloak.org>
- [d] - <https://mms.myaccessid.org/fed-apps/profile/>
- [e] - <https://myaccessid-uk.github.io/site/>
- [f] - <https://clifton.readthedocs.io/stable/>
- [g] - <https://conch.readthedocs.io/stable/>